Checkmate

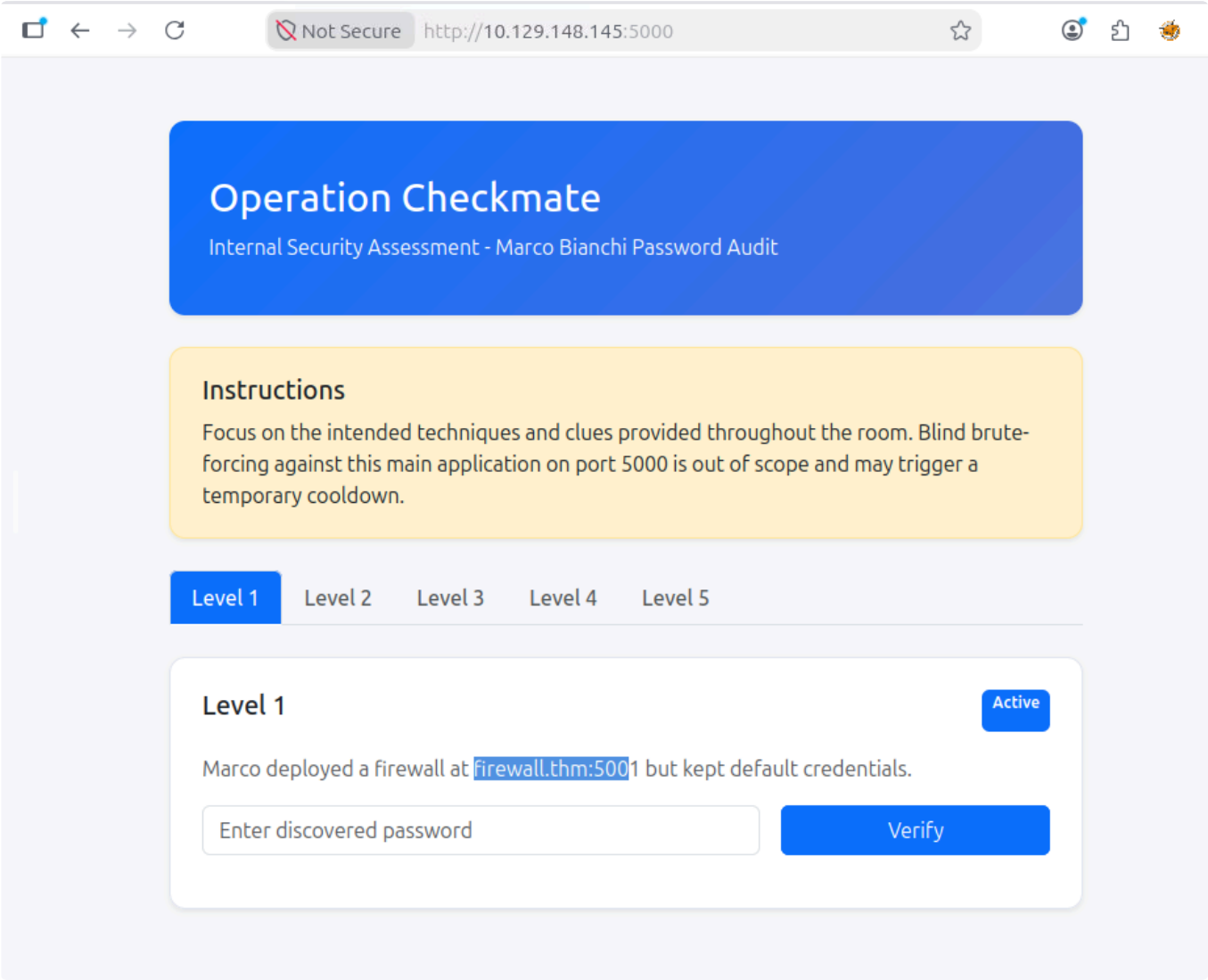
Marco Bianchi, a systems administrator, recently deployed several internal services, including a firewall console, employee portal, social platform, and SSH access to critical infrastructure. Due to tight deadlines and operational pressure, Marco reused weak, predictable, and pattern-based passwords across multiple systems.

Your objective is to conduct a password security assessment to identify weaknesses in Marco's authentication practices.

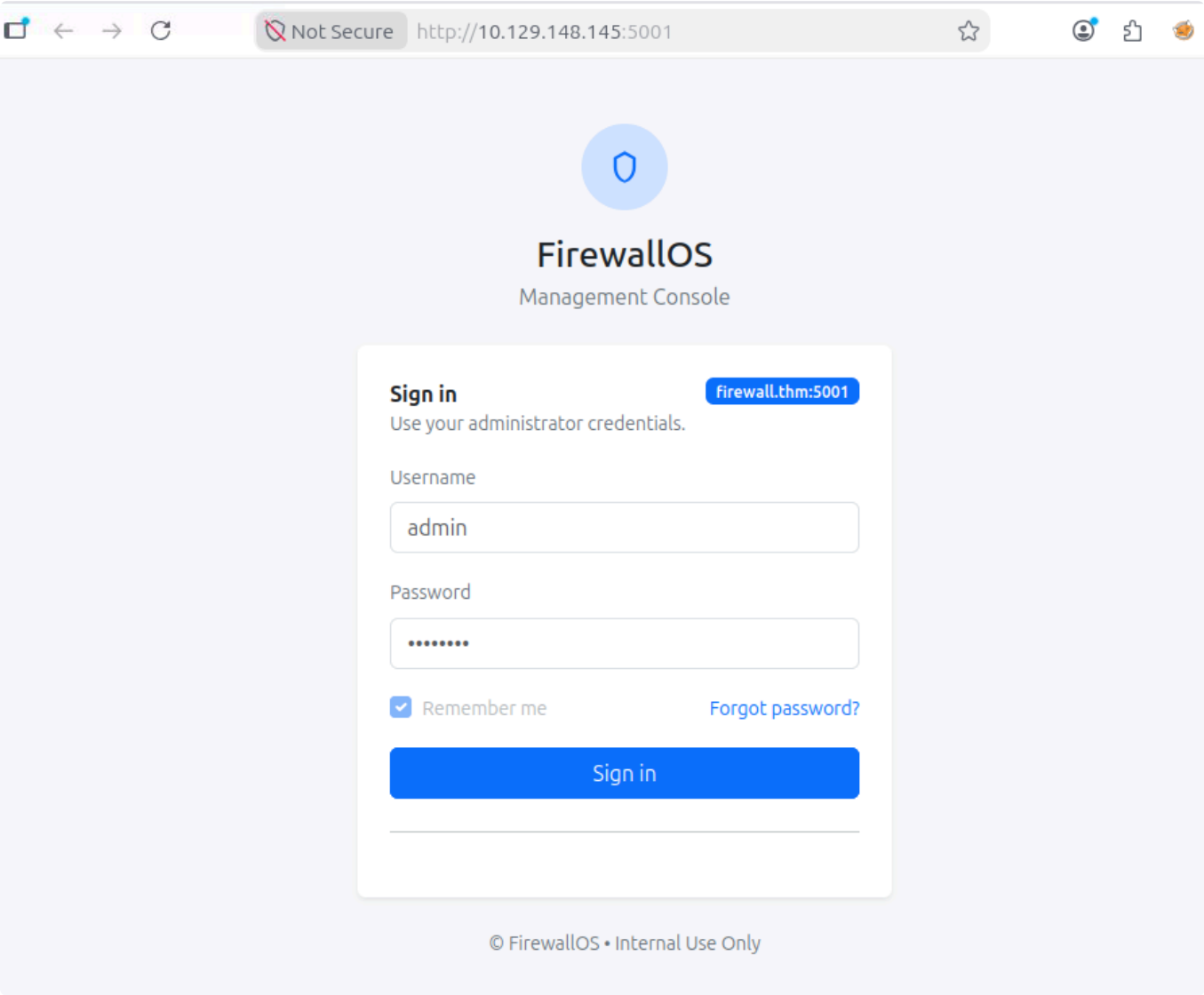


Start by accessing the main application at **http://MACHINE_IP:5000**. From there, you will be guided through each stage of the challenge, uncovering and exploiting weaknesses in Marco's password usage.

Level 1



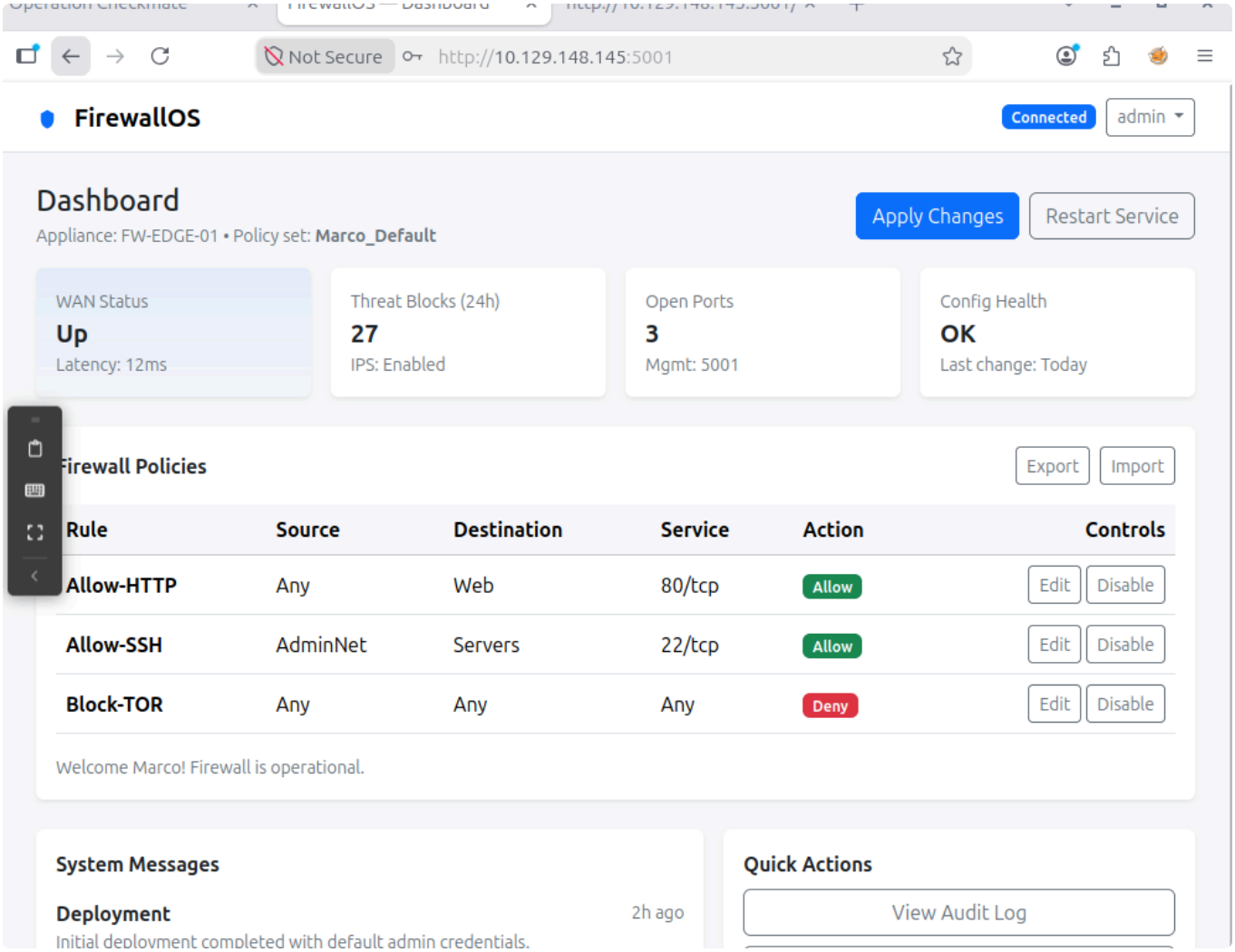
going to the site im greeted with this login page



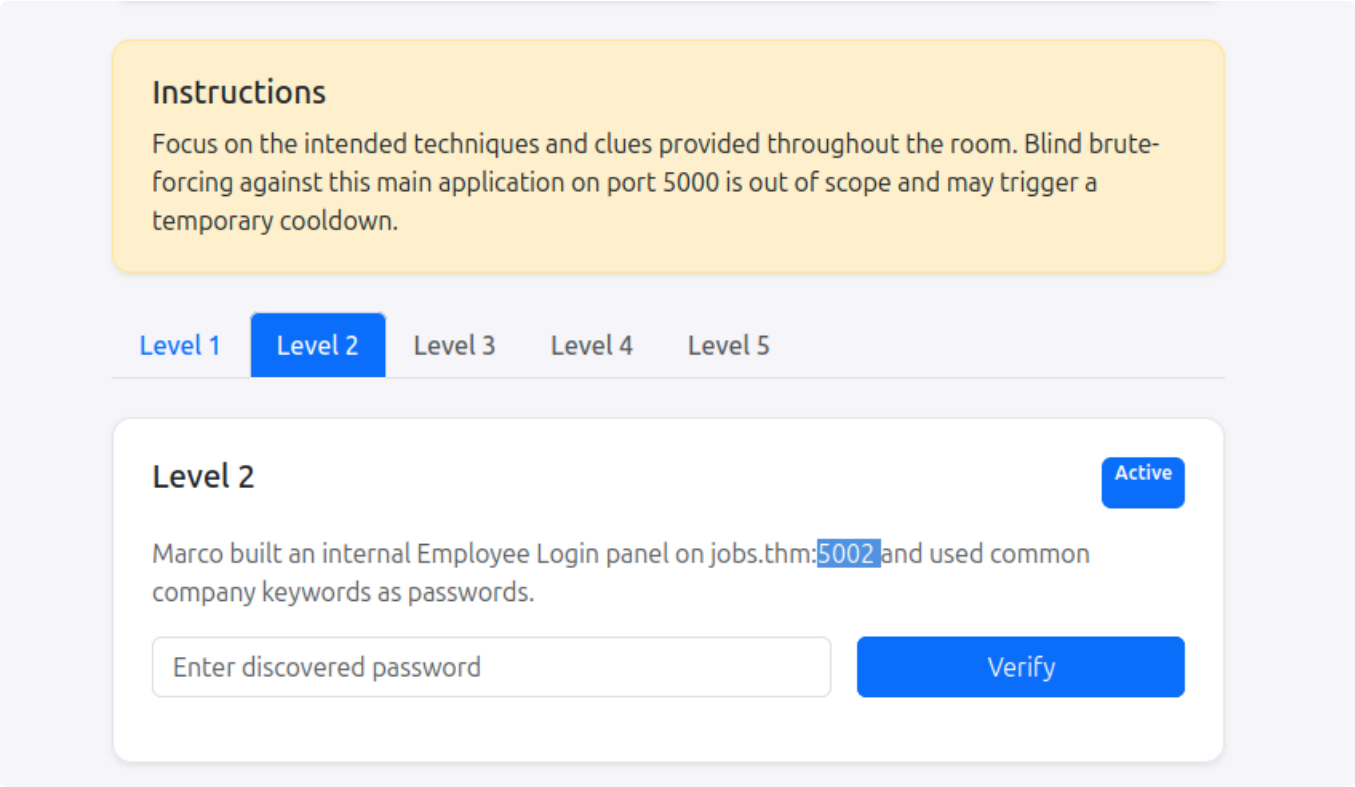
I manually brute forced this by trying common passwords like

admin, password, 12345.

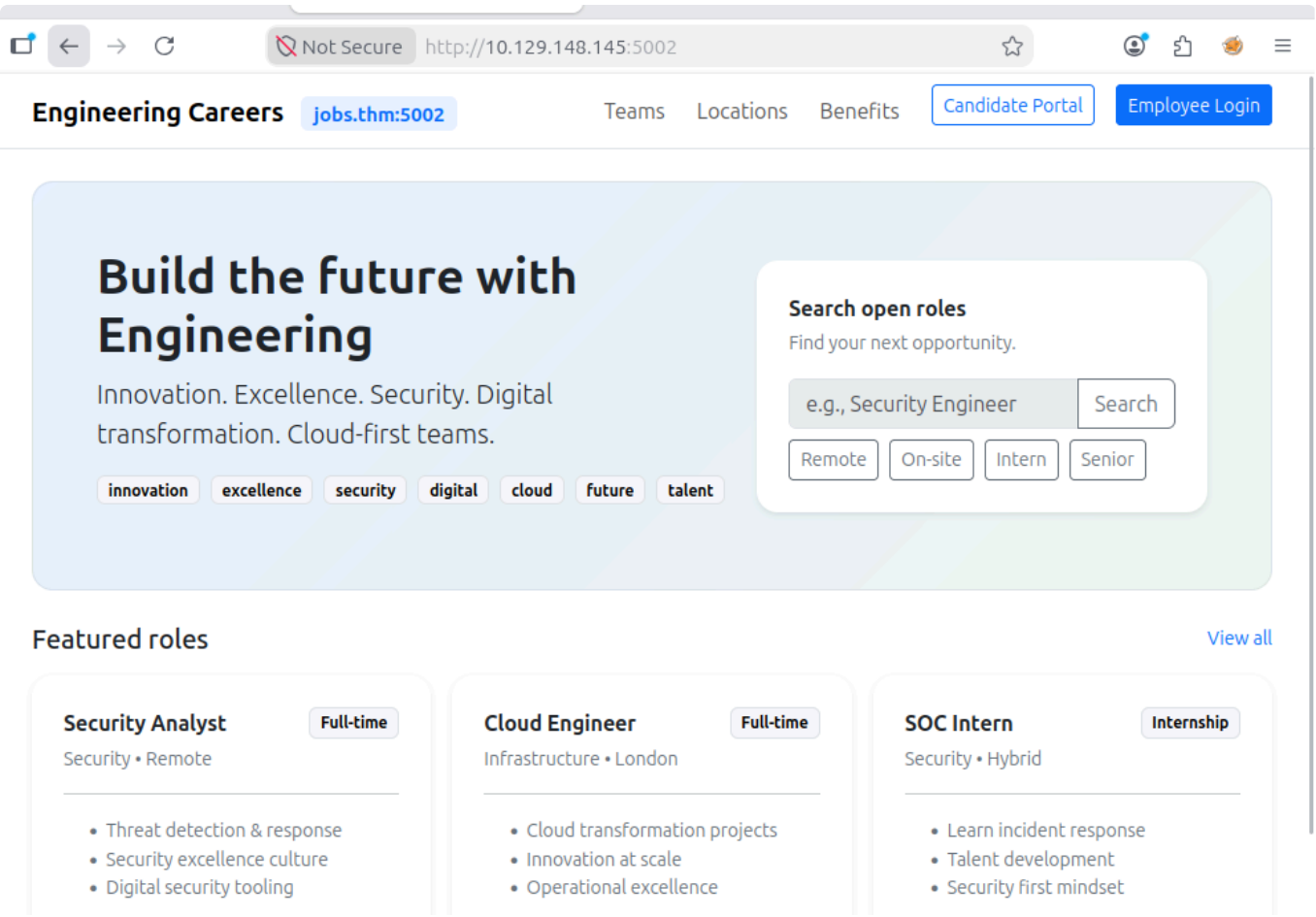
12345 is the password that worked and i got access



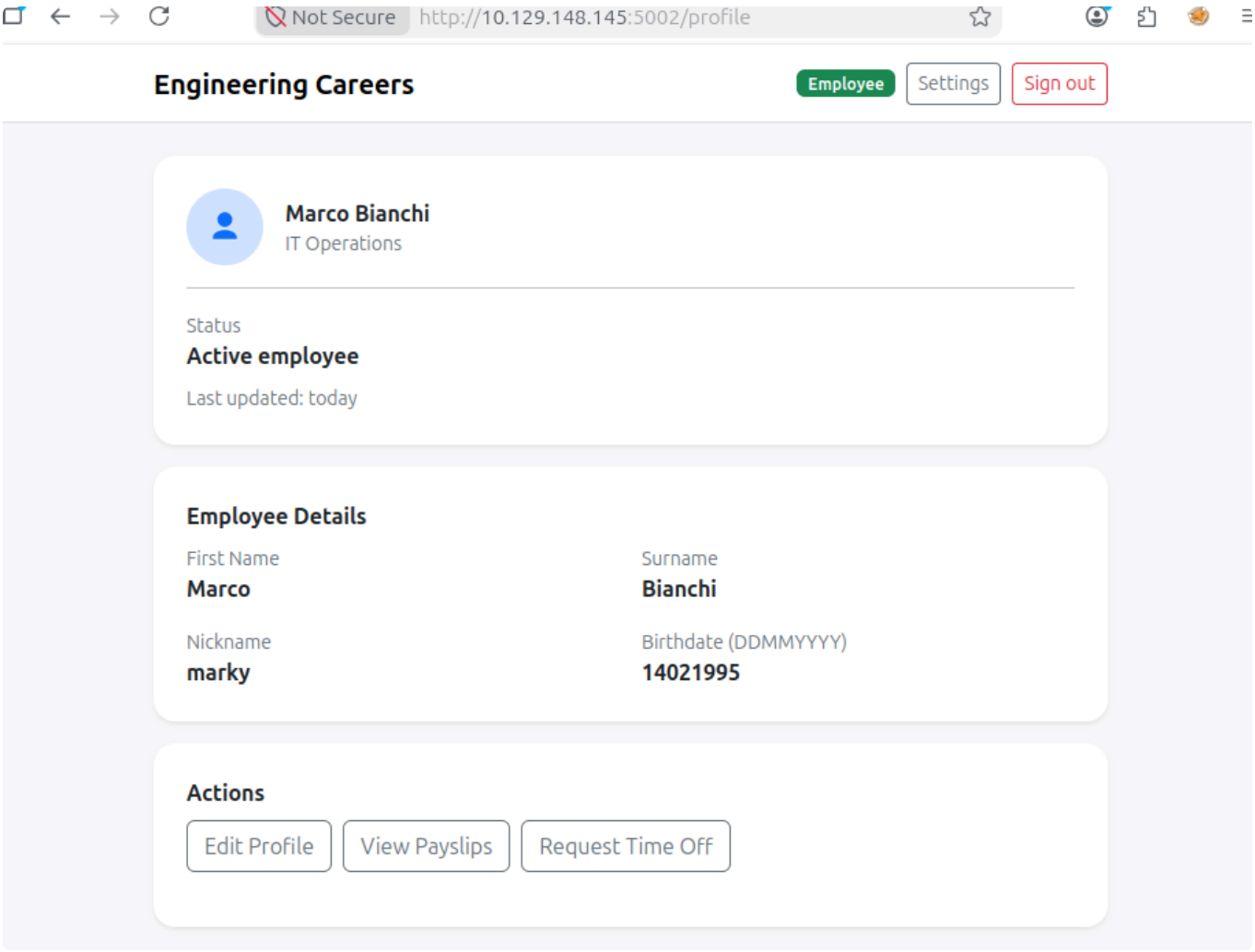
Level 2



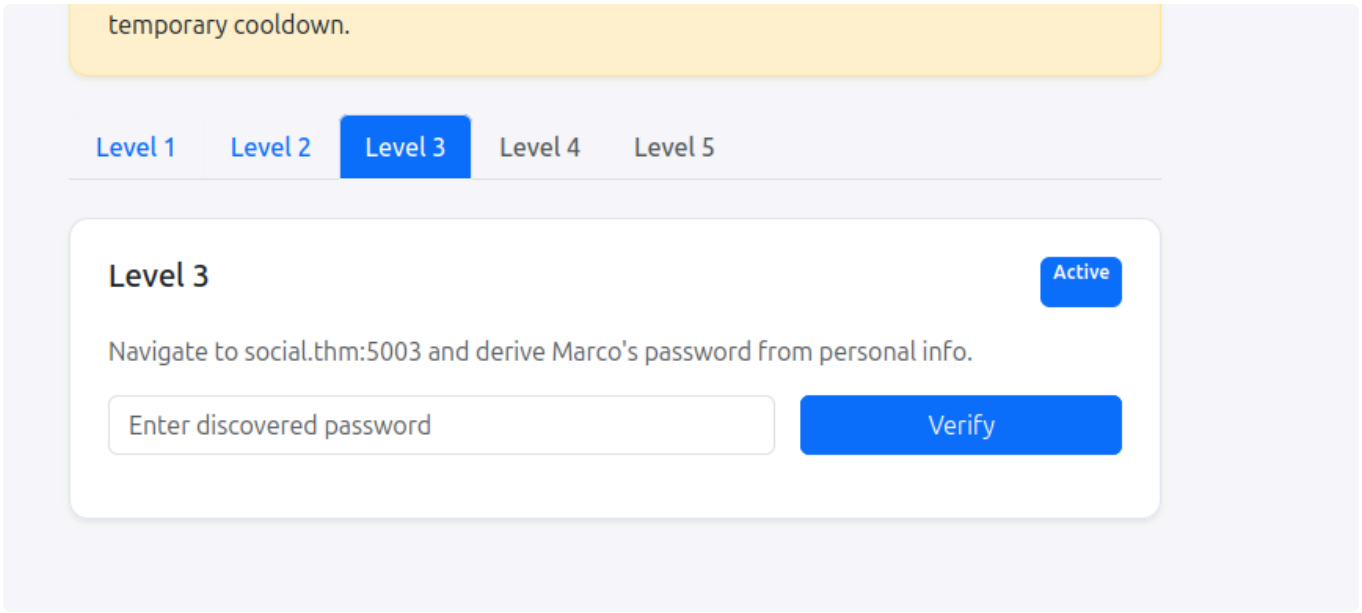
here it says use common company keywords as passwords so i do some recon on the site to find the common keywords



the keyword which was the password was excellence getting access to his info



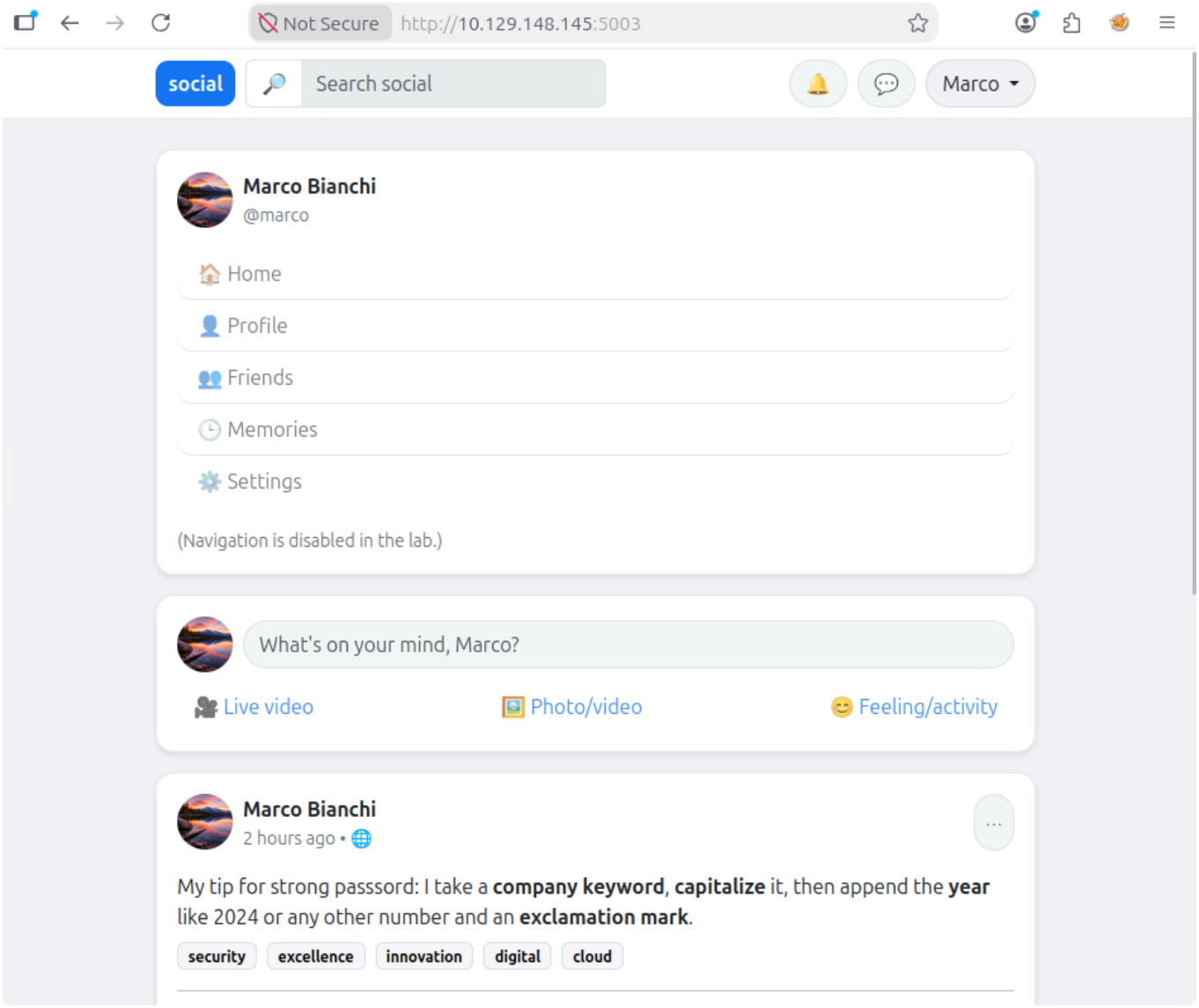
Level 3



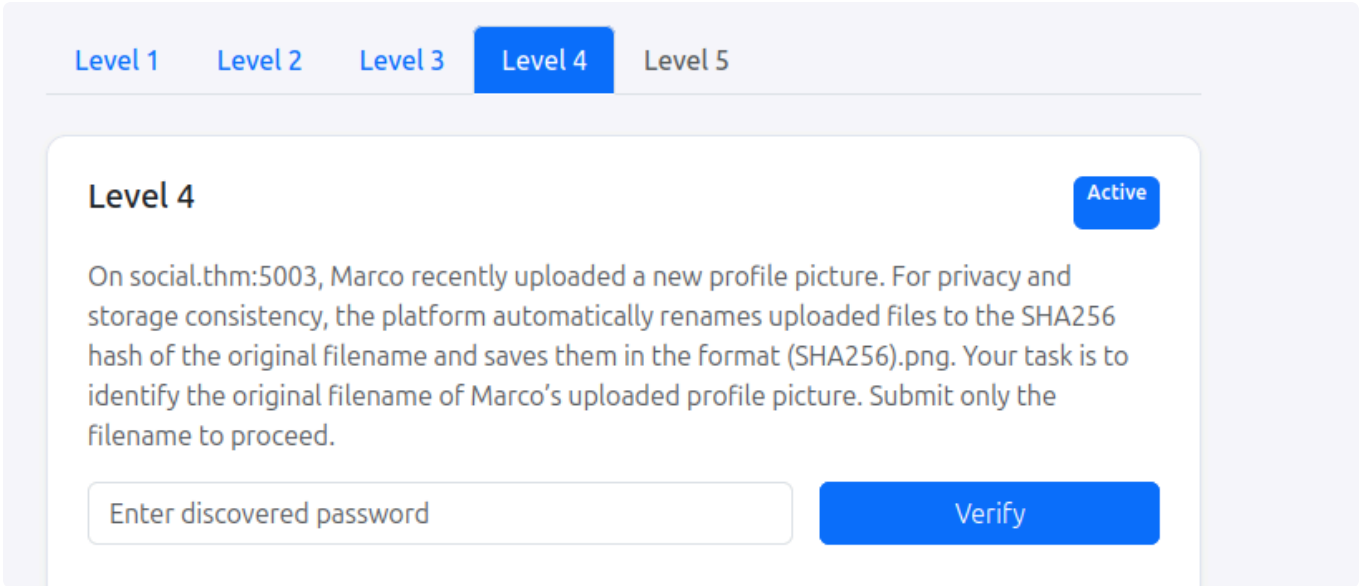
I have to derive marcos password from personal information

I can use the details from the previous level that i got in after logging into marcos account

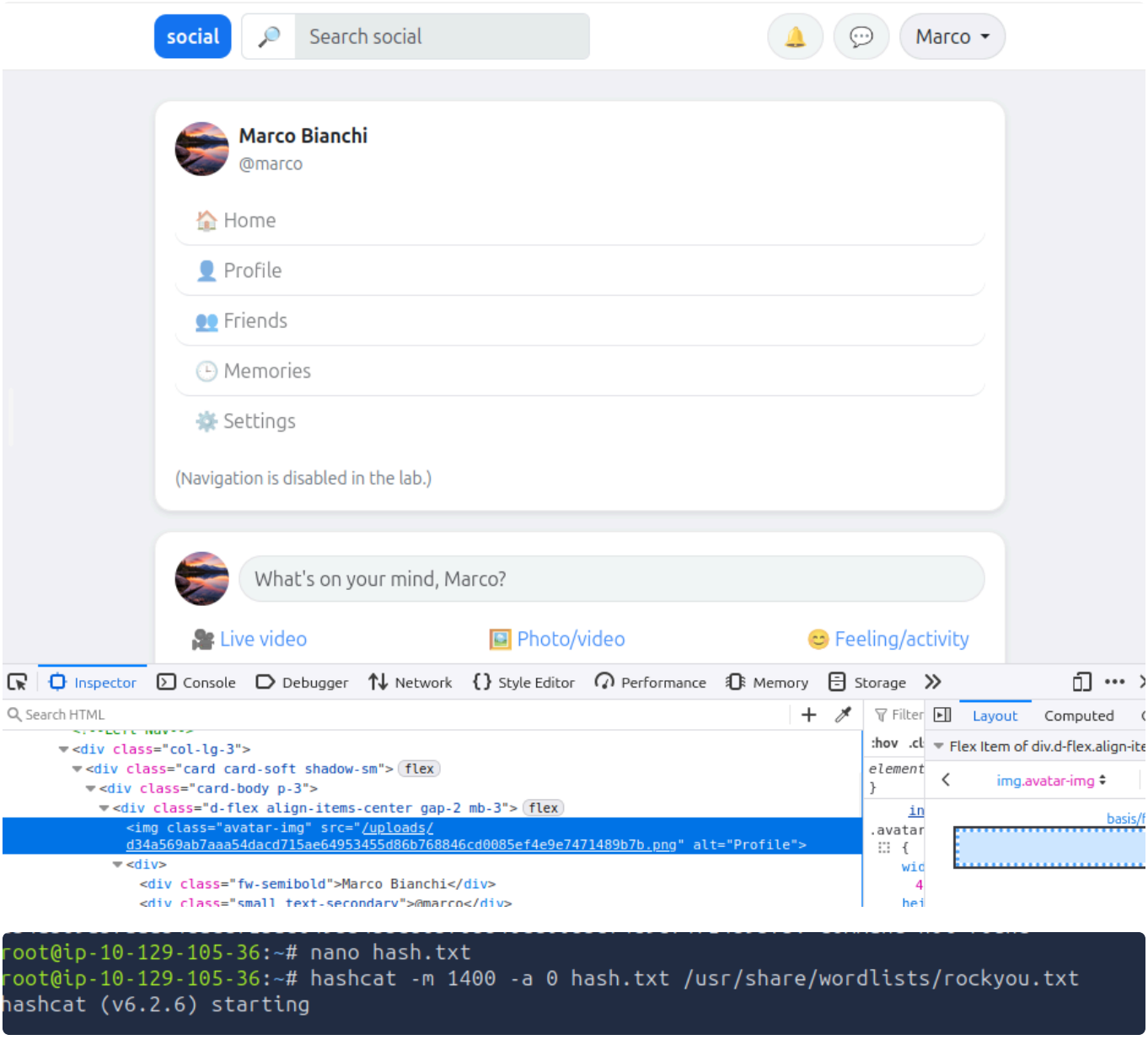
use cupp.py with the details provided from the previous level and it generates the password



Level 4



I used inspector to grab the profile picture and it takes me to where it is displayed and it shows the hash of the png




```
root@ip-10-129-105-36:~# nano hash.txt
root@ip-10-129-105-36:~# hashcat -m 1400 -a 0 hash.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting
```

```
34a569ab7aaa54dacd715ae64953455d86b768846cd0085ef4e9e7471489b7b:family

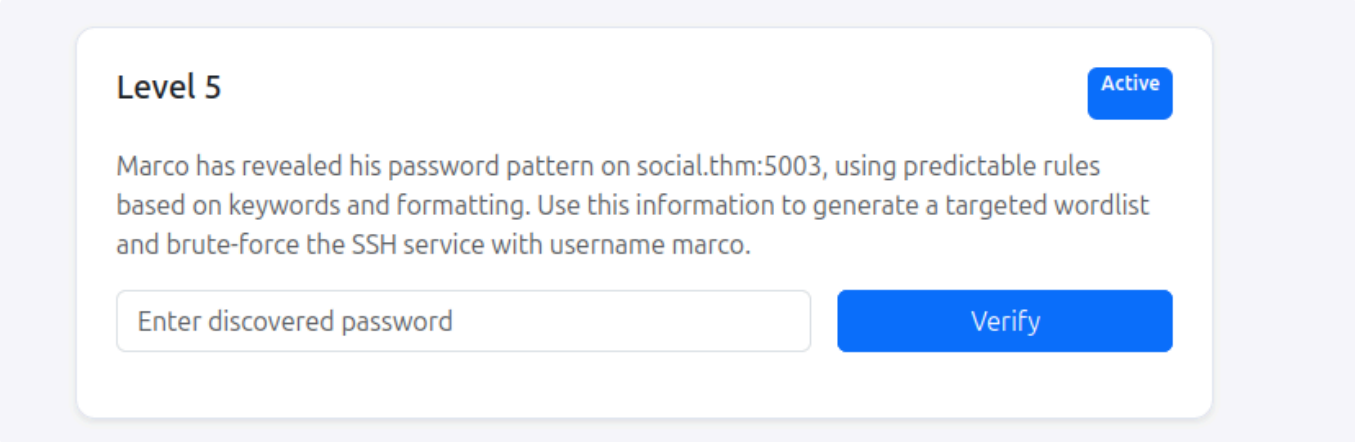
ession.....: hashcat
tatus.....: Cracked
ash.Mode.....: 1400 (SHA2-256)
ash.Target.....: d34a569ab7aaa54dacd715ae64953455d86b768846cd0085ef4...489b7b
ime.Started.....: Mon Sep 14 18:29:30 2026 (0 secs)
ime.Estimated...: Mon Sep 14 18:29:30 2026 (0 secs)
ernel.Feature...: Pure Kernel
uess.Base.....: File (/usr/share/wordlists/rockyou.txt)
uess.Queue.....: 1/1 (100.00%)
peed.#1.....:     8035 H/s (0.18ms) @ Accel:256 Loops:1 Thr:1 Vec:16
ecovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
rogress.....: 512/14344384 (0.00%)
ejected.....: 0/512 (0.00%)
estore.Point....: 0/14344384 (0.00%)
estore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
andidate.Engine.: Device Generator
andidates.#1....: 123456 -> letmein
ardware.Mon.#1..: Util: 54%

tarted: Mon Sep 14 18:28:42 2026
topped: Mon Sep 14 18:29:31 2026
oot@ip-10-129-105-36:~#
```

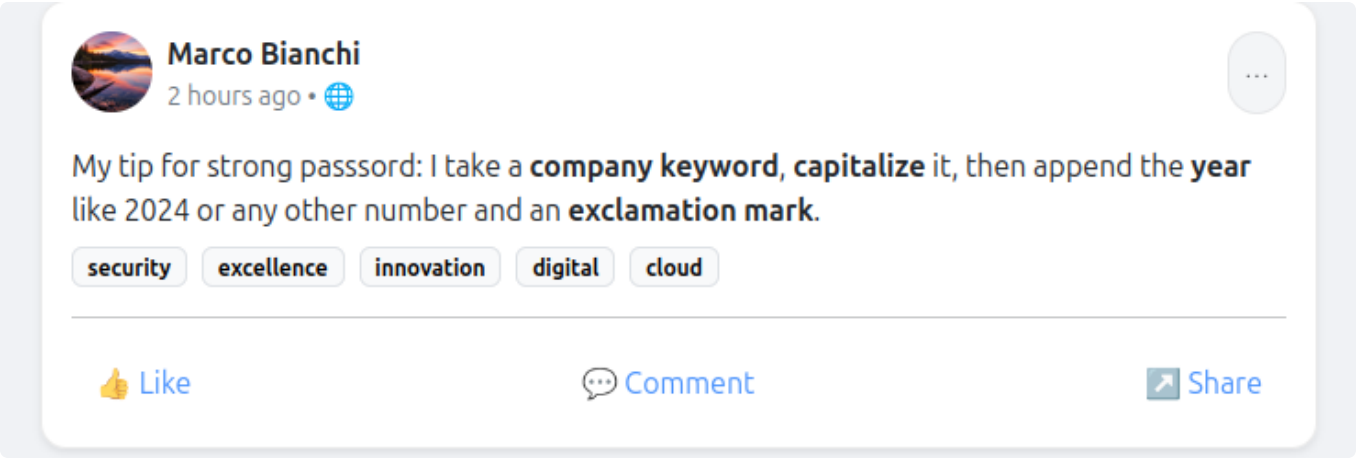
I used the command
hashcat -m 1400 -a 0 hash.txt /usr/share/wordlists/rockyou.txt

the hash i found i put into hash.txt and ran it against a wordlist. the 1400 mode was for the sha256 hashing algorithm

Level 5



on the post it says:



Security2024!